Monthly Intelligence Dispatch

November 2021

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID)) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- New attacks by RedCurl, a corporate cyber espionage threat actor targeting companies in various industries, were detected.
- The arrests and searches that took place this summer in Ukraine were related to an international operation against the **Cl0p** ransomware group, says INTERPOL
- Over 1,000 offers to sell access to companies' networks were made on the dark web. The leading countries with regard to the number of access offers are the United States (30%), France (5%), and the United Kingdom (4%).
- The number of sellers of access to companies' networks in the underground grew by 304%, which is a record. Most of the sellers are Russian speakers.
- The underground market for selling access to companies' networks has grown by 16% and is now $7 million.
- Over the past two years, 34 new ransomware affiliate programs emerged on the dark web: an alliance between initial access brokers and ransomware operators.
- Group-IB assisted Guardia di Finanza in arresting sellers of fake vaccine certificates.
- Carding Action: in two years, Group-IB together with Europol helped European banks save €54 million.

RedCurl

Group-IB detected new attacks by RedCurl, a corporate cyber espionage threat actor targeting companies in various industries. Group-IB reported about the Russian-speaking threat group last year for the first time. Between 2018 and 2020, the group conducted 26 attacks. Victims included companies in the fields of construction, finance, consulting, retail, insurance, and law located in the UK, Germany, Canada, Norway, Russia, and Ukraine. Seven months later, in 2021, RedCurl attacks resumed. Commercial corporate cyber espionage, which RedCurl specializes in, remains a rare and largely unique phenomenon. The group's signature move is sending spear-phishing emails purporting to come from the victim organization's HR department. The hackers use self-developed tools and some publicly available programs to gain initial access, achieve persistence, move laterally, and exfiltrate sensitive documentation. All this means that RedCurl's modus operandi remains unique.

Despite a high level of control over the victim's network, RedCurl does not encrypt infrastructure or withdraw money from accounts. The group strives to obtain valuable information as covertly as possible. RedCurl is mainly interested in the following types of files: business emails, staff records, documents relating to various legal entities, court records, and other internal information. The time from "patient zero" becoming infected to data being stolen can be anywhere from two to six months.

Access sellers

One of the underlying trends on the cybercrime arena is a sharp increase in the number of offers to sell access to compromised corporate networks. Pioneered by the infamous hacker Fxmsp, who was charged by the US Department of Justice in 2020, the market of corporate initial access grew by almost 16% in H2 2020—H1 2021, from $6,189,388 to **$7,165,387**. The number of offers to sell access to companies almost tripled over the review period: from 362 to **1,099**. This exclusive data was obtained by Group-IB's Threat Intelligence & Attribution system, which gathers even deleted information from cybercriminal underground forums. This segment of the cybercriminal underground has a relatively low entry barrier. Poor corporate cyber risk management combined with the fact that tools for conducting attacks against corporate networks are widely available both contributed to a record-breaking rise in the number of initial access brokers. In H2 2019—H12020, the Group-IB Threat Intelligence team detected only 86 active brokers. In H2 2020—H1 2021, however, this number skyrocketed to **262**, with **229** new players joining the roster.

The geography of initial access brokers' operations has also expanded. In H2 2020—H1 2021, the number of countries where cybercriminals broke into corporate networks increased from 42 to **68**. US-based companies are the most popular among sellers of access to compromised networks — they account for 30% of all victim-companies in H2 2020—H1 2021, followed by France (5%), and the UK (4%). The number of offers of access to Australian (4%) and Indian (3%) companies significantly increased. Most initial access brokers are Russian speakers, which makes Russia and other CIS (Commonwealth of Independent States) countries the least targeted.

Carding

Over the review period, the carding market dropped by 26%, **from $1.9 billion to $1.4 billion** compared to the previous period. The decrease can be explained by the lower number of dumps (data stored on the magnetic stripe on bank cards) offered for sale: the number of offers shrank by 17%, from 70 million records to 58 million, due to the infamous card shop Joker's Stash shutting down. Meanwhile, the average price of a bank card dump fell from $21.88 to $13.84, while the maximum price surged from $500 to $750.

An opposite trend was recorded on the market for the sale of bank card text data (bank card numbers, expiration dates, names of owners, addresses, CVVs): their number soared by 36%, from 28 million records to 38 million, which among other things can be explained by the higher number of phishing web resources mimicking famous brands during the pandemic. The average price for text data climbed from $12.78 to $15.2, while the maximum price skyrocketed 7-fold: from $150 to an unprecedented $1,000.

BlackMatter

In November, the **BlackMatter** threat group announced it was shutting down its ransomware-as-a-service (RaaS) program due to "pressure from the authorities". This does not mean, however, that BlackMatter's affiliates will stop malicious activity. They will most likely join other RaaS programs. In addition, this might be an attempt to have a fresh start under a different name. Just like BlackMatter was a rebranding of DarkSide, a new successor may appear soon. In the summer, analysts said that new ransomware emerged right after DarkSide and REvil (the two most active and aggressive threat groups, which attacked major companies such as Toshiba, JBS S.A., Colonial Pipeline, and Kaseya) disappeared from the public eye. While in the summer the researchers had doubts as to who was behind the new ransomware, it is now absolutely clear that BlackMatter is DarkSide's successor. Even though the newcomer has not surpassed its predecessor, it is just a matter of time. A US architectural firm was among the first to fall victim to BlackMatter in late July 2021. Since then, the BlackMatter operators' appetites have grown considerably. The list of BlackMatter's victims consists of more than 50 companies based in the US, Austria, Italy, France, Japan, and other countries. The average ransom demand is $5.3 million, with the maximum reaching $30 million, which the attackers demanded from Japan's Olympus Corporation.

Dharma, Crylock, and Thanos

Group-IB experts made a list of the most aggressive ransomware programs that operated in Russia in 2020–2021. These are Dharma, Crylock, and Thanos, which cumulatively account for over 300 attacks. This year, the number of ransomware attacks in Russia grew by more than 200%. The average ransom paid in Russia in 2021 is about $40,000, while the biggest sum is about $540,000. A record for the sum demanded was set by the threat group OldGremlin, which wanted $3.4 million from their victim. Like in other countries, one of the key reasons for the popularity of ransomware in Russia is the ransomware-as-a-service model, which is used by Dharma, Crylock, and Thanos. Other groups, such as the Russian speaking RTM threat actors, added ransomware to their arsenals to deploy it on compromised networks in case they fail to steal money.

RaaS and DLS

Over the analyzed period (H2 2020 — H1 2021), **21** new affiliate programs emerged on underground forums, which is **19%** more than in the previous period. Between 2020 and 2021, a total of **34** new ransomware affiliate programs were published, with initial access brokers actively participating in them. The access brokers breached companies' networks to sell access to them or participate in affiliate programs to get a percentage from the ransom.

Threat actors mastered the use of **data leak sites** (DLSs), which are used as an additional source of pressure on victims to make them pay the ransom by threatening to leak their data. The number of new DLSs more than doubled **from 13** new DLSs in H2 2019 – H1 2020 **to 28** new ones in H2 2020 – H1 2021. The number of victims whose data has been published on DLSs has grown by **935%**, from 229 (in H2 2019 – H1 2020) to **2,371** (in H2 2020 – H1 2021).

As such, for the whole of 2020, data belonging to **1,335 ransomware victims** was published on DLSs, and in the first three quarters of 2021 alone, data belonging to **1,966** victims was published, which is **47%** more than for the entire previous year. Given that the data of only **10%** of victim companies is published on DLSs, their actual number is dozen times higher. In addition, about 30% of victims pay the ransom.

In 2021, Group-IB analysts concluded that **Conti** was the most aggressive ransomware group that used a DLS: it disclosed information about 361 victims (16.5% of all victim companies whose data was released on DLSs), followed by **Lockbit** (251), **Avaddon** (164), **REvil** (155), and **Pysa** (118). Last year's top 5 was as follows: Maze (259), Egregor (204), Conti (173), REvil (141), and Pysa (123).

Country-wise, most companies whose data was posted on DLSs by ransomware operators in 2021 were based in the United States (968), Canada (110), and France (103), while most organizations affected belonged to the manufacturing (9.6%), real estate (9.5%), and transportation industries (8.2%).

QR codes

Starting from early September, Group-IB's Digital Risk Protection team has revealed 3,158 new offers to sell vaccination certificates. This is 20 times more than in the summer of 2021. Most of the new offers were published in Telegram chats. Compared to the summer of 2021, vaccination certificate creation time and price has changed. Back then, the price varied between $35 and $350, and it took about three weeks to have a certificate created. Now, however, certificates cost anywhere between $54 and $163, and sellers promise to deliver them in as little as three days. The range of services is also growing. In addition to certificates for Russian vaccines, such as Sputnik V, EpiVacCorona, and CoviVac (translated into English), sellers offer non-Russian vaccine certificates such as Pfizer, CoronaVac, AstraZeneca, and Moderna. The primary channels where information about selling certificates is distributed are public Telegram chats, single-page websites, and social media pages. In addition to vaccination certificates, sellers offer positive or negative PCR tests, Covid-19 anti-body certificates, QR codes, and vaccination exemptions.

Arrests and sentences

Green Pass

Group-IB assisted **Guardia di Finanza** (GdF), the Italian law enforcement agency responsible for dealing with financial crime, in a probe into the activities of a criminal group that trafficked fake Green Passes (electronic documents issued for vaccinated Italian citizens, individuals who tested negative, and people who recently recovered from COVID-19) via the Telegram messenger. On October 15, Green Passes became mandatory in Italy; in addition to visiting museums, movie theatres, gyms, and restaurants, they started to be required to get to the workplace. Group-IB's Amsterdam-based hi-tech crime investigation department detected 35 Telegram channels that sold fake Green Passes. Sellers claimed that in order to receive a Green Pass, the victim had to provide their personal data in a secret Telegram chat supposedly to have a QR code generated. On average, a fake Green Pass cost about €100 and could be paid using cryptocurrency, PayPal transfers, or Amazon gift cards. Once scammers received their victim's data or money, they disappeared or sent the victim a fake certificate. Thanks to information collected by Group-IB experts, Guardia di Finanza made arrests and conducted searches in Veneto, Liguria, Apulia, and Sicily.

Carding Action

Group-IB took part in **Carding Action 2021**, a cross-border operation coordinated by Europol's European Cybercrime Centre (EC3) aimed at countering the sale of bank card data. In three months, experts collected and provided the police with payment data relating to 50,000 compromised bank cards. This helped European banks prevent €14 million worth of potential losses. The data was collected from several proprietary sources such as botnet and JS-sniffer infrastructure, as well as underground card shops and marketplaces monitored by Group-IB's Threat Intelligence & Attribution system. Operation Carding Action started last year. At the time, Group-IB provided European law enforcers with information on 90,000 bank cards. As a result, European financial organizations prevented €40 million worth of potential losses, according to Europol.

Arrests and sentences

Cl0p

The arrests and searches that took place this summer in Ukraine were related to an international operation against the **Cl0p** ransomware group, INTERPOL said. The action was coordinated by Singapore's Cyber Fusion Centre (CFC). In addition to law enforcers, Trend Micro, Kaspersky Lab, Palo Alto Networks, Fortinet and Group-IB took part in the operation (codenamed Operation Cyclone). In June, the Ukrainian police reported an arrest of six individuals who the investigators believe laundered money for the Cl0p ransomware operators. The latter have not been arrested but they have been put on an international wanted list. INTERPOL created Red Notices and — on South Korea's request — sent them to their representatives in 194 countries. The Cl0p ransomware operators are known for their attacks against major Korean retailers and US educational institutions. In addition to encrypting files, the threat actors steal their victims' data and threaten to publish it if the ransom is not paid. INTERPOL estimates damages from the group behind Cl0p at over $500 million.

Forecasts and warnings

- The forecasts and recommendations contained in Hi-Tech Crime Trends are aimed at reducing financial losses and infrastructure downtime. They are also designed to help organizations take preventive measures to counteract targeted attacks, espionage, and cyber-terrorism operations.
- The most active ransomware that operated in the post-Soviet region, **Dharma**, **Crylock,** and **Thanos**, were cumulatively involved in more than **300** attacks. The data of companies from Russia and other CIS (Commonwealth of Independent States) countries was not published on DLSs, however. This technique is likely to be used in the future.
- Experts expect the sales of bank card data in the underground to gradually decline. First and foremost, this will affect data dump sales.
- The most common method of delivering ransomware to the networks of Russian organizations is compromising publicly accessible terminal servers via Remote Desktop Protocol (RDP). In 2021, such attacks accounted for 60% of all cyberattacks investigated by Group-IB. Phishing mailouts are second making up 22% of incidents. Vulnerabilities in publicly available applications are third accounting for 14% of incidents.

If you wish to receive more detailed information about a specific incident, threat, or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+65 3159 3798
+7 495 984 33 64
intelligence@group-ib.com